

NIMBUSGUARD TECHNOLOGIES, INC.

Security Incident Response Plan

Detection, Triage, Containment, Recovery & Lessons Learned

Document ID:	NG-IRP-004	Version:	5.0
Effective Date:	January 25, 2026	Owner:	VP Operations – James Wright
Classification:	Internal – Confidential	Status:	Approved

1. Incident Classification

Severity	Definition	Response Time	Notification
SEV-1 (Critical)	Active data breach, complete service outage, ransomware, or complete degradation of critical systems	15 minutes	CSIRT, CISO, CEO, legal, affected customers within 1 hour
SEV-2 (High)	Partial service degradation, suspected intrusion, or vulnerability disclosure	30 minutes	CSIRT, SOC, DevOps, affected teams within 2 hours
SEV-3 (Medium)	Failed intrusion attempt, policy violation, or critical system compromise	4 hours	Security team, relevant system owners
SEV-4 (Low)	Phishing attempt, minor policy deviation, or non-critical security issue	24 hours	Security team via ticketing system

2. Incident Response Team

The Computer Security Incident Response Team (CSIRT) comprises the following core members: Incident Commander (rotating SRE lead), Security Analyst (SOC team), Forensic Investigator, Communications Lead, Legal Counsel, and relevant Engineering leads. The on-call rotation ensures 24/7/365 coverage with a guaranteed 15-minute response time for SEV-1 events.

3. Detection and Monitoring

NimbusGuard operates a 24/7 Security Operations Center (SOC) staffed by a combination of internal analysts (Tier 2/3) and a managed detection service (Arctic Wolf, Tier 1). Detection capabilities include:

- SIEM: Splunk Enterprise Security with over 850 custom correlation rules
- EDR: CrowdStrike Falcon on all endpoints and servers
- CNAPP: Wiz for cloud workload protection, vulnerability management, and posture management
- NDR: Darktrace for network traffic analysis and anomaly detection
- WAF: AWS WAF with managed rule sets (OWASP Core, Bot Control, IP Reputation)
- DLP: Nightfall AI for data loss prevention across SaaS applications and code repositories

4. Response Phases

4.1 Identification – Alert is triaged by SOC analyst, severity assigned, and CSIRT notified per escalation matrix.

4.2 Containment – Immediate actions to limit blast radius: isolate affected systems, revoke compromised credentials, block malicious IPs/domains.

4.3 Eradication – Remove root cause: patch vulnerabilities, remove malware, reset affected accounts, rebuild compromised systems from known-good images.

4.4 Recovery – Restore services from verified backups, validate system integrity, gradually re-enable access with enhanced monitoring.

4.5 Lessons Learned – Post-incident review (PIR) held within 5 business days. Root cause analysis documented. Corrective actions tracked in Jira with defined owners and deadlines.

5. Breach Notification

In the event of a confirmed data breach involving personal data, NimbusGuard will: notify the relevant supervisory authority within 72 hours of becoming aware of the breach (per GDPR Article 33); notify affected data subjects without undue delay where the breach is likely to result in high risk to their rights and freedoms (per GDPR Article 34); notify affected customers contractually within 48 hours via the designated security contact; and file reports with relevant US state attorneys general as required by applicable breach notification laws.

6. Forensic Readiness

NimbusGuard maintains forensic readiness through: centralized immutable log storage with a minimum 13-month retention period; pre-authorized forensic disk imaging tools deployed on all infrastructure; chain-of-custody procedures documented and tested quarterly; and a retainer agreement with CrowdStrike Services for supplemental forensic investigation support.